SUBDOMAIN ENUMERATION: KĨ THUẬT THU THẬP VÀ PHÁT HIỆN SUBDOMAIN

Liệt kê tên miền phụ là quá trình tìm kiếm các tên miền phụ hợp lệ cho một tên miền chính, nhưng tại sao chúng ta lại làm điều này? Chúng ta làm điều này để mở rộng bề mặt tấn công nhằm phát hiện thêm nhiều điểm yếu tiềm tàng.

Chúng ta sẽ tìm hiểu ba phương pháp liệt kê tên miền phụ khác nhau: Tấn công vét cạn (Brute Force), Tình báo nguồn mở (OSINT) và Máy chủ ảo (Virtual Host).

1. OSINT – SSL/TLS Certificates

Khi một chứng chỉ SSL/TLS (Secure Sockets Layer/Transport Layer Security) được tạo cho một tên miền bởi một CA (Certificate Authority), các CA sẽ tham gia vào cái gọi là "Nhật ký Minh bạch Chứng chỉ (Certificate Transparency - CT)". Đây là những nhật ký công khai về mọi chứng chỉ SSL/TLS được tạo cho một tên miền. Mục đích của nhật ký Minh bạch Chứng chỉ là để ngăn chặn việc sử dụng các chứng chỉ độc hại và được tạo ra một cách vô tình. Chúng ta có thể tận dụng dịch vụ này để tìm ra các tên miền phụ thuộc vào một tên miền, các trang web như https://crt.sh cung cấp cơ sở dữ liệu chứng chỉ có thể tìm kiếm, hiển thị kết quả hiện tại và lịch sử.

Chúng ta sẽ truy cập crt.sh và tìm kiếm tên miền tryhackme.com và tìm mục được ghi lại vào ngày 26/12/2020.

4047116843	2021-02-08	2021-02-08	2021-05-09	blog.tryhackme.com	blog.tryhackme.com	C=US, O=Let's Encrypt, CN=R3
3844506055	2020-12-29	2020-12-29	2021-03-29	docs.tryhackme.com	docs.tryhackme.com	C=US, O=Let's Encrypt, CN=R3
3844507250	2020-12-29	2020-12-29	2021-03-29	docs.tryhackme.com	docs.tryhackme.com	C=US, O=Let's Encrypt, CN=R3
3833434859	2020-12-26	2020-12-26	2021-03-26	store.tryhackme.com	store.tryhackme.com	C=US, O=Let's Encrypt, CN=R3
3833430615	2020-12-26	2020-12-26	2021-03-26	store.tryhackme.com	store.tryhackme.com	C=US, O=Let's Encrypt, CN=R3
3754926363	2020-12-09	2020-12-08	2021-03-08	blog.tryhackme.com	blog.tryhackme.com	C=US, O=Let's Encrypt, CN=R3
3754926282	2020-12-09	2020-12-08	2021-03-08	blog.tryhackme.com	blog.tryhackme.com	C=US, O=Let's Encrypt, CN=R3
3575622060	2020-10-30	2020-10-30	2021-01-28	docs.tryhackme.com	docs.tryhackme.com	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
3575622041	2020-10-30	2020-10-30	2021-01-28	docs.tryhackme.com	docs.tryhackme.com	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
3563687936	2020-10-27	2020-10-27	2021-01-25	store.tryhackme.com	store.tryhackme.com	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3
3563684925	2020-10-27	2020-10-27	2021-01-25	store.tryhackme.com	store.tryhackme.com	C=US, O=Let's Encrypt, CN=Let's Encrypt Authority X3

What domain was logged on crt.sh at 2020-12-26?

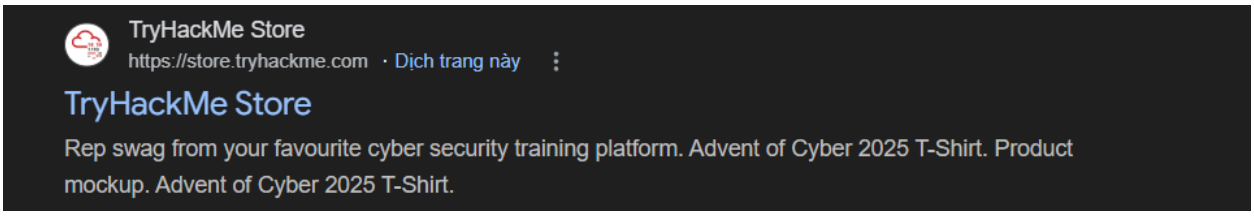
store.tryhackme.com

✓ Correct Answer

2. OSINT – Search Enginers

Các công cụ tìm kiếm chứa hàng nghìn tỷ liên kết đến hơn một tỷ trang web, đây có thể là một nguồn tài nguyên để tìm kiếm các tên miền phụ mới. Sử dụng các phương pháp tìm kiếm nâng cao trên các trang web như Google, chẳng hạn như bộ lọc site:, có thể thu hẹp kết quả tìm kiếm. Ví dụ: site:*.domain.com -site:www.domain.com sẽ chỉ chứa các kết quả dẫn đến tên miền domain.com nhưng loại trừ bất kỳ liên kết nào đến www.domain.com; do đó, nó chỉ hiển thị cho chúng ta các tên miền phụ thuộc vào domain.com.

Chúng ta sẽ sử dụng Google và sử dụng cụm từ tìm kiếm site:*.tryhackme.com -site:www.tryhackme.com



What is the TryHackMe subdomain beginning with **S** discovered using the above Google search?

store.tryhackme.com

✓ Correct Answer

3. DNS Bruteforce

Phương pháp dò tìm DNS (Hệ thống Tên miền) bằng vũ lực là cách thử hàng chục, hàng trăm, hàng nghìn hoặc thậm chí hàng triệu tên miền phụ khác nhau từ một danh sách các tên miền phụ thường dùng đã được định sẵn. Vì phương pháp này yêu cầu rất nhiều yêu cầu, chúng ta tự động hóa nó bằng các công cụ để làm cho quá trình nhanh hơn. Trong trường hợp này, chúng ta đang sử dụng một công cụ có tên là dnsrecon để thực hiện việc này.

```
user@thm:~$ dnsrecon -t brt -d acmeitsupport.thm
[*] No file was specified with domains to check.
[*] Using file provided with tool: /usr/share/dnsrecon/namelist.txt
[*]     A api.acmeitsupport.thm 10.10.10.10
[*]     A www.acmeitsupport.thm 10.10.10.10
[+] 2 Record Found
user@thm:~$
```

What is the first subdomain found with the dnsrecon tool?

api.acmeitsupport.thm

✓ Correct Answer

4. OSINT – Sublist3r

Để tăng tốc quá trình khám phá tên miền phụ OSINT, chúng ta có thể tự động hóa các phương pháp trên với sự trợ giúp của các công cụ như Sublist3r.

```
user@thm:~$ ./sublist3r.py -d acmeitsupport.thm
[-] Total Unique Subdomains Found: 2
web55.acmeitsupport.thm
www.acmeitsupport.thm
user@thm:~$
```

What is the first subdomain discovered by sublist3r?

web55.acmeitsupport.thm

✓ Correct Answer

5. Virtual Hosts

Một số tên miền phụ không phải lúc nào cũng được lưu trữ trong kết quả DNS công khai, chẳng hạn như các phiên bản phát triển của ứng dụng web hoặc cổng quản trị. Thay vào đó, bản ghi DNS có thể được lưu giữ trên máy chủ DNS riêng hoặc được ghi lại trên máy của nhà phát triển trong tệp /etc/hosts (hoặc tệp c:\windows\system32\drivers\etc\hosts đối với người dùng Windows), tệp này ánh xạ tên miền đến địa chỉ IP.

Vì máy chủ web có thể lưu trữ nhiều trang web từ một máy chủ duy nhất, khi một trang web được yêu cầu từ máy khách, máy chủ sẽ biết trang web nào mà máy khách muốn từ tiêu đề Host. Chúng ta có thể sử dụng tiêu đề Host này bằng cách thay đổi nó và theo dõi phản hồi để xem liệu chúng ta có phát hiện ra một trang web mới hay không.

Tương tự như với tấn công Bruteforce DNS, chúng ta có thể tự động hóa quá trình này bằng cách sử dụng danh sách từ các tên miền phụ thường được sử dụng.

Chúng ta sẽ sử dụng máy chủ ảo của tryhackme và thực hiện các lệnh:

```
ffuf -w /usr/share/wordlists/SecLists/Discovery/DNS/namelist.txt -H "Host: FUZZ.acmeitsupport.thm" -u http://10.49.172.236
```

Lệnh trên sử dụng tùy chọn -w để chỉ định danh sách từ mà chúng ta sẽ sử dụng. Tùy chọn -H thêm/chỉnh sửa tiêu đề (trong trường hợp này là tiêu đề Host), chúng ta có từ khóa FUZZ ở vị trí thường dành cho tên miền phụ, và đây là nơi chúng ta sẽ thử tất cả các tùy chọn từ danh sách từ.

```
root@ip-10-49-127-123: ~
 :: Filter           : Response size: 2395
_____________________________________________________

:: Progress: [40/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Error
:: Progress: [207/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Erro
:: Progress: [380/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Erro
delta                   [Status: 200, Size: 51, Words: 7, Lines: 1, Duration: 0m
s]
:: Progress: [481/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Erro
:: Progress: [559/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Erro
:: Progress: [732/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Erro
:: Progress: [902/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Erro
:: Progress: [1081/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Err
:: Progress: [1266/1907] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Err
:: Progress: [1438/1907] :: Job [1/1] :: 1398 req/sec :: Duration: [0:00:01] ::
:: Progress: [1612/1907] :: Job [1/1] :: 1398 req/sec :: Duration: [0:00:01] ::
:: Progress: [1785/1907] :: Job [1/1] :: 1408 req/sec :: Duration: [0:00:01] ::
yellow                  [Status: 200, Size: 56, Words: 8, Lines: 1, Duration: 8m
s]
:: Progress: [1907/1907] :: Job [1/1] :: 1379 req/sec :: Duration: [0:00:01] ::
:: Progress: [1907/1907] :: Job [1/1] :: 1459 req/sec :: Duration: [0:00:01] ::
:: Progress: [1907/1907] :: Job [1/1] :: 1459 req/sec :: Duration: [0:00:01] ::
Errors: 0 ::
```

What is the first subdomain discovered?

delta

✓ Correct Answer

What is the second subdomain discovered?

yellow

✓ Correct Answer